

Poonawalla Fincorp Limited

Information & IT Risk Management Policy

Effective Date: 17.10.2025
Approval Date: 17.10.2025
Version No.: 6.0
Approved By: Board of Directors
Policy Owner: Information Security team

This document is internal to PFL in nature and supersedes any existing Policy on Information security policy in the Company and should be read in conjunction with the most recent policies and procedures documented.

INFORMATION & IT RISK MANAGEMENT POLICY

Document review and approval

Document Control

Document Name	Information & IT Risk Management Procedure
Document Version	6.0
Release Date	27 th April 2020
Frequency of review	Annually
Effective Date	17.10.2025
Approved by	Board of Directors
Reviewed by	Chief Information Security Officer

Version Details

Date	Author	Version	Review Details
09/08/2019	Shilpa Shewale	1.0	Updated changes. Reviewed by CISO
27/04/2020	Shilpa Shewale	2.0	Updated changes. Reviewed by CISO
04/01/2023	Hiten Kumar	3.0	Updated changes. Reviewed by CISO
20/10/2023	Hiten Kumar	4.0	Update the version details, ISMS control reference and likelihood of occurrence
18/01/2024	Hiten Kumar	5.0	Renamed Policy Document and updated as per new RBI IT governance, Risk and assurance direction
25/10/2024	Hiten Kumar	-	Annual Review. No changes suggested
17/10/2025	Saurabh Kumar	6.0	Changes in Risk Assessment Methodology

Document ownership

This document is owned by Poonawalla Fincorp Limited – Information Security Department.

No part of this document may be copied, reproduced, translated, or reduced to any electronic medium or machine-readable form without prior written permission from Poonawalla Fincorp Limited (PFL).

Table of Contents

1.	Introduction	5
2.	Objective	5
3.	Scope	5
4.	Frequency of IT Risk Assessment	5
5.	Roles and Responsibilities.....	6
6.	IT Risk Assessment – Process Flow	6
7.	Risk Assessment Methodology	7
7.1	Process Identification	7
7.2	Identify Applicable Threats and Associated Vulnerability.....	7
7.3	Identify the Risk.....	7
7.4	Mapping with ISMS Controls	8
7.5	Risk Assessment	8
7.6	Risk Rating Calculation	10
7.7	Risk Acceptance Criteria.....	10
7.8	Risk Mitigation and Treatment	11
7.9	Revised Impact and Probability of Occurrence	11
7.10	Calculation of Residual Risk	11
	Annexures.....	13
	Annexure 8.1: Terms of Reference.....	13
	Annexure 8.2: Vulnerability Sources	13
	Annexure 8.3 - Risk Acceptance Form (RAF)	13
	Annexure 8.4 - ISMS Controls Reference	13

1. Introduction

This document outlines the IT risk assessment methodology and provides guidance to identify relevant risks. Further, it also outlines the frequency of performing IT risk assessments. The document details the procedure through which Poonawalla Fincorp is required to identify and handle the risks it might be exposed to within the realm of its Information Security Management System. It also provides clarity on responsibilities and accountabilities for the various participants in the overall management of risk in the organization. It encompasses the following areas:

- Criteria for performing IT risk assessment and frequency of IT risk assessment.
- Identifying the processes and their related risks, applicable threats, vulnerabilities, and existing controls.
- Estimating the impact and probability of threat and vulnerability.
- Identify the risk owner.
- Evaluating the risks against risk acceptance criteria.
- Determining how risks are to be treated and criteria for accepting identified risks.
- Obtain risk owner's approval on risk treatment plan and acceptance of the residual risk.
- Outlining how risk decisions need to be communicated.

2. Objective

The primary goal of this document is to protect the organization and its ability to perform its daily operations. Therefore, IT Risk Assessment Methodology is not to be treated primarily as a technical function carried out by the IT experts who operate and manage the IT system, but as an essential management function of the organization. The objective of performing Risk Management is to enable the organization to accomplish its mission(s) by:

- Securing the systems that store, process, or transmit organizational information.
- Enabling management to make well-informed risk management decisions to justify the expenditures that are a part of the budget.

3. Scope

This policy and procedure are applicable to all information assets, processes, departments and locations of Poonawalla Fincorp.

4. Frequency of IT Risk Assessment

It is required that IT Risk Assessments are performed on yearly basis or any of the following events (may not be exhaustive):

- If major changes are contemplated to existing systems/assets or business processes
- Significant changes to the facilities or in cases where there is a relocation of facilities e.g., movement of application from on-prem to cloud or SaaS, change of DR site etc.
- New or re-emerging threats that could be active both outside and inside the organization and have not been assessed (changes to the threat landscape)
- Changes in business continuity plans

As the IT risk assessment is a point in time review, it is imperative that IT risk assessments are frequently examined (at least once a year) to ensure that changes in the business and operational environments are taken into consideration.

5. Roles and Responsibilities

5.1 Risk Manager (Infosec Team)

IT Risk Manager is responsible for IT Risk Assessment exercise and its effective implementation. The Risk Manager is also responsible for creating and maintaining the Risk Register, ensuring this is reviewed and approved periodically by management.

5.2 Risk Owner

Risk owners are to be assigned for each risk identified during the assessment. He/she will have accountability and authority to manage/mitigate the associated risk.

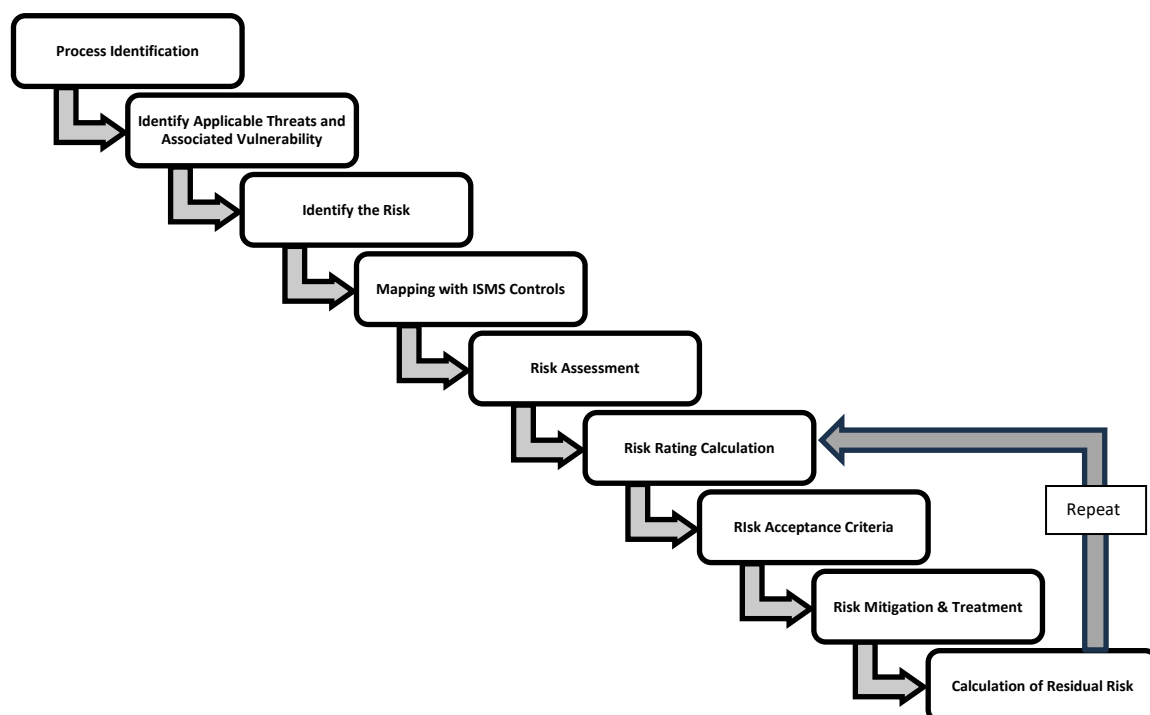
The Risk Owner has the following responsibilities:

- Assess & mitigate risk as per the risk mitigation plan.
- Present risk status at ITSC meeting.

5.3 ITSC

IT risk assessments including IS risk should be brought to the notice of the Chief Risk Officer (CRO), Chief Information Officer (CIO), if any, CTO (Chief Technology Officer and / Chief Transformation Officer) and the Board of directors.

6. IT Risk Assessment – Process Flow



7. Risk Assessment Methodology

7.1 Process Identification

All the department SPOCs will identify the processes running in their respective departments which affect the organization's business operations. It is highly recommended that the processes are classified based on the impact on the business operations. Following criteria are to be considered:

- The Confidentiality, Integrity, Availability (CIA) impact on the process
- Breaches of information security (e.g. loss of Confidentiality, Integrity and Availability)
- Impaired operations/system outages (internal or third parties)
- The loss of business and financial value
- Disruption of plans and deadlines
- Damage of reputation
- Breaches of legal and regulatory, or contractual requirements

7.2 Identify Applicable Threats and Associated Vulnerability

It is highly recommended that all the relevant information security threats to the organization, internal and external context, are considered during the risk assessment exercise.

- Identify the internal and external issues which are relevant to Organization, Processes etc.
- Identification of external issues, such as political, economic, social, technological, legal, and environmental can be considered.
- For identification of internal issues policies, procedures, work culture, changes within Organization etc. can be considered.
- Identify the needs and expectations of internal and external interested parties which may be in stated, obligatory or generally implied form.
- Identify the dependencies of Organization on internal and external persons, entities or factors which may be affecting the information security and its intended outcome.
- Identify the legal, regulatory, statutory requirements which are applicable to the Organization and may pose risks to information security.
- Identify the requirements arising through the contractual obligations with partners, suppliers, service providers, customers, other entities which may pose risks to information security.
- Identify information security, business, strategic etc. objectives which are set or defined by the Organization.
- Identify the information and information assets possessed by the Departments and Organization which needs to be considered for risk assessment.
- Identify the core processes and support processes which are required by the Organization to achieve the intended outcome.

7.3 Identify the Risk

- For identification of risks, consider all contexts which are identified as part of section 7.2
- Identify the Vulnerabilities for all the contexts which may cause Threats to cause the Risk
- Identify the various Threats which can exploit said Vulnerability to cause Risk
- Identify the undesired situations or events or incidents (Risks) which may be caused by the Threats exploiting the Vulnerability
- For each Risk, identify the impacts or consequences which may be caused
- Identify if the Risk has any impact on Confidentiality or Integrity or Availability
- Based on the impact assessment, decide whether the overall Impact is 'Acceptable' or 'Not Acceptable'
- For each Risk, identify the likelihood or probability of the risk occurring

- The likelihood may be identified as 'Yes' if there is any possibility of such risk occurring.
- The impacts and likelihood may be identified based on knowledge, previous incidents, historical data, information available or perception, knowledge about absence of control measures etc.
- While identifying the risks or impacts, focus shall be maintained on confidentiality or integrity or availability or all.

Examples of information security risk categories:

- Data theft
- Unavailability of systems
- Interruptions in business/support process
- Loss of information
- Non availability of premises
- Legal and regulatory non-compliance
- Theft
- Data privacy breach
- Data integrity breach
- Third party risk
- Software Failure
- Compromise of confidentiality
- Non-compliance with organizational policies & procedures

7.4 Mapping with ISMS Controls

- Identify if the Risk has any impact on Confidentiality or Integrity or Availability.
- Information assets in the defined scope shall be guided by ISO 27001 Standard and its annexure.
- Mapping the identified risk with ISMS controls with Annexure 8.5 - ISMS Controls Reference.

7.5 Risk Assessment

Any relevant threat applicable to Poonawalla Fincorp can cause loss of Confidentiality, Availability, and Integrity (CIA). Every threat scenario might not be applicable on all the factors including Confidentiality, Integrity, and Availability (CIA). The CIA rating based on the impact estimated on Confidentiality, Integrity and Availability is described below:

7.5.1 Confidentiality Impact

What is the impact, if information associated with the process gets leaked to unauthorized sources due to lack of adequate existing preventive controls in the organization?		
Rating	Value	Impact on Confidentiality
Critical	5	Very serious adverse impact with legal / financial/ regulatory/ operational implications
High	4	Serious adverse impact
Medium	3	Moderate but negative impact
Low	2	Limited adverse effect
Very Low	1	Negligible impact

7.5.2 Integrity Impact

What is the impact if information associated with the process is altered or deleted without authorization due to lack of adequate existing preventive controls in the organization?		
Rating	Value	Impact on Integrity
Critical	5	Very serious adverse impact with legal / financial/ regulatory/ operational implications
High	4	Serious adverse impact
Medium	3	Moderate but negative impact
Low	2	Limited adverse effect
Very Low	1	Negligible impact

7.5.3 Availability Impact

What is the impact if information associated with the process is not available due to lack of adequate existing preventive controls in the organization?		
Rating	Value	Impact on Integrity
Critical	5	Very serious adverse impact with legal / financial/ regulatory/ operational implications
High	4	Serious adverse impact
Medium	3	Moderate but negative impact
Low	2	Limited adverse effect
Very Low	1	Negligible impact

Note: The impact rating is dependent on the existing controls which may be changed as per the level of existing preventive controls implemented.

7.5.4 Probability of Occurrence

The probability of occurrence rating is the probable value assigned to quantify the likelihood of a threat materializing based on the identified vulnerability. The scale has been defined as given below:

While determining the probability, the frequency in terms of how often it might occur, past experience and statistics may be considered. The likelihood of failure occurrence is valued using the following scale:		
Rating	Value	Probability Of Occurrence
High	3	The event is likely to occur within 1 – 12 months. The event has a high probability of occurring unless corrective action is applied.
Medium	2	The event is likely to occur within 12 – 36 months. There is a reasonable probability that this event will occur.
Low	1	The event is likely to occur within 3 – 5 years, probability of this happening is low.

7.6 Risk Rating Calculation

The 'Risk Value' is calculated after considering the probability of the occurrence of the event, impact and existing controls that are implemented effectively.

Overall Impact = Highest of (Confidentiality Impact, Integrity Impact & Availability Impact);

$$\text{Risk Value} = (\text{Probability of Occurrence}) \times (\text{Overall Impact})$$

Probable Risk Values: {1, 2, 3, 4, 5, 6, 8, 9, 10, 12, 15}

Risk Matrix		Overall Impact				
		Very Low (1)	Low (2)	Medium (3)	Very High (4)	Critical (5)
Probability of Occurrence	Low (1)	1	2	2	4	5
	Medium (2)	2	4	6	8	10
	High (3)	3	6	9	12	15

Risk Value	Risk Rating
15	Critical
12	High
10	
9	
8	Medium
6	
5	
4	
3	Low
2	
1	

7.7 Risk Acceptance Criteria

Based on business drivers and the perception of risk in Poonawalla Fincorp; CTO, CISO and respective heads of departments are required to determine the risks that are acceptable to the organization.

Risks with risks value (or revised risk value) ≤ 4 will be treated as acceptable risks.

Acceptable Risk Threshold Value	Risk Value ≤ 4
---------------------------------	---------------------

Risks which are categorized as "Low" (risk value ≤ 4) rating risks are required to be treated as an **acceptable risk** and further action is not required in such cases. Such risks would be treated as "Residual risks" and would have to be accepted by head of department.

Note: The management can also decide to take actions against low risks which can have severe impact in future as per the business requirements.

7.8 Risk Mitigation and Treatment

Identification and Evaluation of risk treatment plan: Risk treatment plan is prepared for all critical, high, and medium risks identified. It is highly recommended that the risk treatment is prioritized based on the resources needed, Business impact/Investment required/Time required to implement the controls/complexity or difficulty associated with implementation, weighing these factors against the associated risks and benefits derived. Also, the existing controls are reviewed before necessary additional controls to mitigate the risk are considered.

Definition and implementation of necessary systems, procedures, and controls to ensure secure storage/ transmission/ processing of data/ information.

All Risks which have risk value of more than four (Risk Value > 4), prioritize the treatment Risk prioritization is as below-

- For Risks with 'Critical' Level, treat the risks within **30 Days** period.
- For Risks with 'High Level', treat the risks within **60 Days** period.
- For Risks with 'Medium' Level, treat the Risks within **120 Days** period.
- *Note: Vulnerabilities identified in the VAPT assessments, and their respective closures will be tracked or addressed as per defined PFL VAPT process; as VAPT is a proactive measure to detect and prevent known and unknown vulnerabilities; any vulnerabilities or group of vulnerabilities without proper exception approvals may be included in risk assessments.*

There are four possible ways of treating the risks, as detailed below:

Applying appropriate controls to reduce the risk: In order to reduce the assessed risks, it is required that appropriate and justified security controls are identified and selected. The aim of control selection is to reduce risk to a level which is acceptable to Poonawalla Fincorp. This selection is to be supported by the results of risk assessment. It is highly recommended that pre-existing controls are re-examined in terms of cost comparisons, including maintenance, with a view to remove or improve them if they are not effective enough.

Avoiding the risks: Risk avoidance describes any action where business processes are discontinued or stopped in order to avoid a particular risk. When evaluating the option of risk avoidance, it needs to be balanced against business and monetary needs.

Risk transfer / sharing with other parties: Risk sharing with another entity might be the best option if it seems impossible to avoid the risk, and it is difficult or too expensive, to achieve appropriate reduction of risk.

Accepting risk: Risk acceptance criteria can be defined as the amount of risk, on a broad level, an entity is willing to accept in pursuit of its objectives.

Risk Rating	Acceptances Required from
Critical	CTO/ CIO / CRO / CISO
High	
Medium	

7.9 Revised Impact and Probability of Occurrence

The revised impact and probability of occurrence is prepared for all residual risk existing within a process. These values are revised after implementation of mitigation controls.

7.10 Calculation of Residual Risk

The residual risk is the risk faced by the organization after implementing the controls. The residual risk is to be arrived based on the formulae below:

$$\text{Residual Risk} = (\text{Revised Probability of Occurrence}) \times (\text{Revised Overall Impact})$$

The residual risks shall be classified as per the process mentioned in section 7.6.

If the residual risk is above the acceptable threshold value, measures are required to be considered to reduce risk levels by applying further controls. In case the organization is unable to reduce the risk in these cases, then appropriate approvals and acceptance are required to be obtained. This decision is based on the risks involved and the impact on the business.

Risk Assessment/Risk treatment register will be used to centrally record, manage, and track information security risks across Poonawalla Fincorp.

Annexures

Annexure 8.1: Terms of Reference

- **Control:** Means of managing risk, including policies, procedures, guidelines, practices or organizational structures, which can be of administrative, technical, management or legal nature
- **Vulnerability:** A vulnerability is the susceptibility or weakness of a resource to any negative impact from hazardous events, i.e. a weakness or flaw that enables a threat to attack an information system.
- **Threat:** A threat is a potential for a source to exercise (accidentally trigger or intentionally exploit) a specific vulnerability.
- **Guideline:** A description that clarifies what should be done and how, to achieve the objectives set out in policies
- **Information Processing Facilities:** Any information processing system, service or infrastructure, or the physical locations housing them
- **Information Security:** Preservation of confidentiality, integrity and availability of information; in addition, other properties, such as authenticity, accountability, non – repudiation, and reliability can also be involved
- **Policy:** Overall intention and direction as formally expressed by management
- **Third Party:** That person or body that is recognized as being independent of the parties involved, as concerns the issue in question.

Annexure 8.2: Vulnerability Sources

The vulnerabilities associated with information systems could be identified via the information-gathering techniques by developing effective questionnaires. The Internet is another source of information on known system vulnerabilities posted by vendors, along with hot fixes, service packs, patches, and other remedial measures that may be applied to eliminate or mitigate vulnerabilities.

Vulnerability sources that shall be considered include, but are not limited to, the following:

- Vulnerability Assessment report conducted for the PFL information systems
- The information system's risk assessment reports, audit reports, system anomaly reports, and evaluation reports
- Vulnerability lists, such as the CVE, CVSS, NIST vulnerability database
- Security and Product specific vendor advisories

Annexure 8.3 - Risk Acceptance Form (RAF)

The risks which are identified and cannot be treated due to business, functional or technical dependency should be presented to management as exceptions. Respective RAF forms should be filled to seek any such exception or summary of the risks should be presented to respective management level committees.



RAF-Final%20Template%20v1.0.docx

Risk Acceptance Form (docx)

Annexure 8.4 - ISMS Controls Reference



ISMS%20Control%20Reference%20v2.0.xls

ISMS Controls Reference (xls)